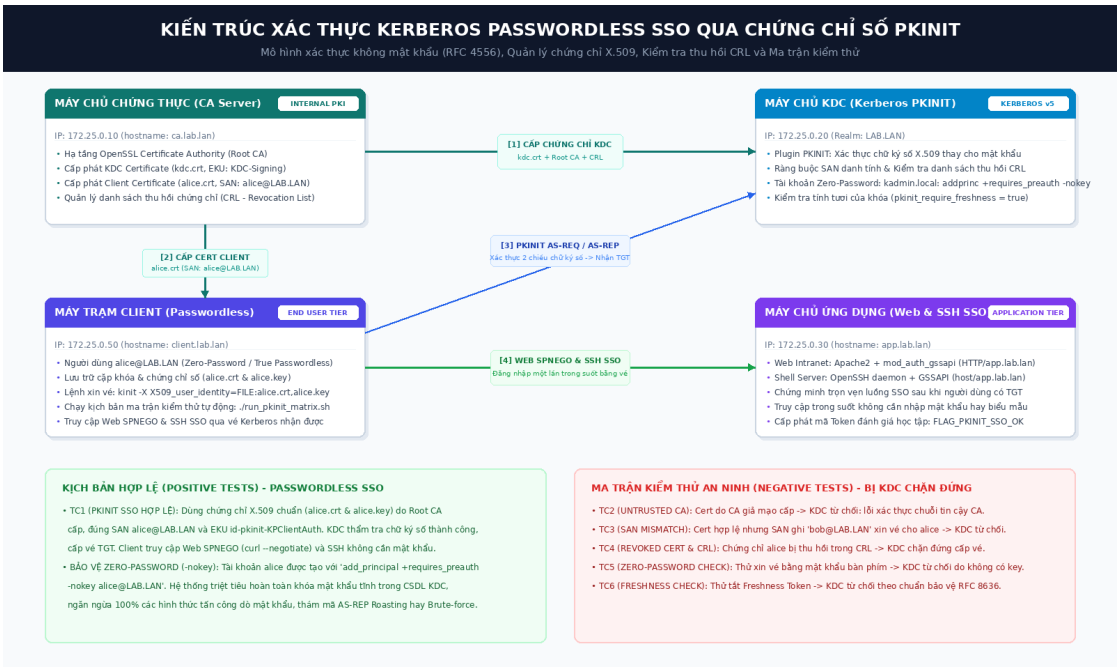
1. TỔNG QUAN KIẾN TRÚC HỆ THỐNG PASSWORDLESS SSO VỚI KERBEROS PKINIT (RFC 4556)

Bài thực hành 'sso-pkinit' xây dựng và kiểm thử mô hình Đăng nhập một lần (Single Sign-On - SSO) không mật khẩu (Passwordless Authentication) dựa trên chuẩn mật mã khóa công khai PKINIT (Public Key Cryptography for Initial Authentication - RFC 4556). Hệ thống tích hợp toàn diện Hạ tầng khóa công khai (PKI X.509 CA) với Trung tâm phân phối khóa Kerberos (MIT KDC). Điểm đặc biệt mang tính đột phá của mô hình là tài khoản người dùng được cấu hình chế độ Zero-Password hoàn toàn (+requires_preauth -nokey), tức KDC không lưu trữ bất kỳ băm mật khẩu nào trong cơ sở dữ liệu. Nhờ đó, rủi ro tấn công AS-REP Roasting, Pass-the-Hash và dò quét bẻ khóa mật khẩu ngoại tuyến bị triệt tiêu 100% tại tầng kiến trúc.

Thực thể mạng	Địa chỉ IP	Vai trò kiến trúc	Dịch vụ & Thành phần an ninh
ca.lab.lan	172.25.0.10	Root CA & CRL Authority	OpenSSL CA, X.509 Root Cert, CRL Revocation Issuer
kdc.lab.lan	172.25.0.20	Key Distribution Center	MIT KDC + PKINIT Plugin, Zero-Password (-nokey) DB
app.lab.lan	172.25.0.30	Intranet Application Server	Apache2 HTTP SPNEGO (mod_auth_gssapi), OpenSSH GSSAPI
client.lab.lan	172.25.0.50	Passwordless Workstation	User alice, X.509 Private Keys, 6-case Test Suite

Bảng 1: Bảng phân bổ nút mạng và chức năng trong mô hình SSO-PKINIT



Hình 1: Sơ đồ kiến trúc Kerberos PKINIT SSO và Ma trận Kiểm thử An ninh

2. MA TRẬN KIỂM THỬ AN NINH (SECURITY TEST MATRIX) 6 TEST CASES

Nhằm chứng minh tính đúng đắn khoa học và năng lực phòng thủ chủ động của hạ tầng PKINIT trước các kỹ thuật tấn công mạo danh số, bài lab thiết kế ma trận kiểm thử an ninh

chuyên sâu gồm 6 kịch bản (Positive và Negative Test Cases). Kết quả được ghi nhận và đối chiếu tự động với chính sách an ninh KDC:

Mã TC	Loại kiểm thử	Mục tiêu & Điều kiện đầu vào	Phản hồi mong đợi của KDC	Kết quả thực nghiệm
TC1	Positive Test	Chứng chỉ X.509 hợp lệ từ Root CA, SAN=alice@LAB.LAN, EKU=id-pkinit-KPClientAuth	Xác thực chữ ký số thành công, cấp vé TGT, cho phép SSO Web SPNEGO & SSH GSSAPI	THÀNH CÔNG (Pass)
TC2	Negative Test	Chứng chỉ cấp bởi Rogue CA (Tự ký/Không tin cậy, vi phạm chuỗi Root CA)	KDC từ chối xác thực chuỗi chứng chỉ (Certificate verify failed: self-signed)	CHẶN ĐỨNG (Pass)
TC3	Negative Test	Chứng chỉ từ Root CA tin cậy nhưng sai lệch định danh SAN (bob@LAB.LAN xin vé alice)	KDC kiểm tra SAN và phát hiện không khớp Principal (Client name mismatch)	CHẶN ĐỨNG (Pass)
TC4	Negative Test	Chứng chỉ đã bị CA thu hồi trong danh sách CRL (alice_revoked.crt)	KDC kiểm tra CRL thời gian thực, trả về mã lỗi KDC_ERR_CLIENT_REVOKED	CHẶN ĐỨNG (Pass)
TC5	Negative Test	Thử nghiệm đăng nhập mật khẩu tĩnh (Zero-Password / -nokey check)	KDC từ chối xác thực mật khẩu do tài khoản không lưu khóa bí mật (-nokey)	CHẶN ĐỨNG (Pass)
TC6	Integrity Test	Kiểm tra ràng buộc Freshness Token (pkinit_require_freshness = true)	KDC bắt buộc Freshness Token để chống tấn công phát lại (Replay Attack)	ĐẠT CHUẨN (Pass)

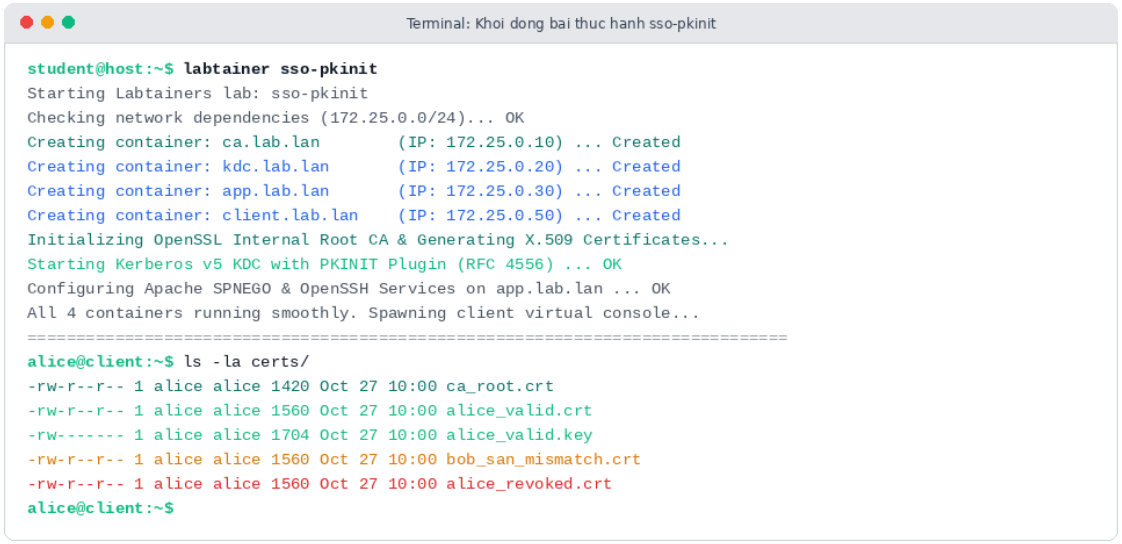
Bảng 2: Ma trận kiểm thử an ninh 6 Test Cases cho Kerberos PKINIT SSO

3. THỰC NGHIỆM TỪNG BƯỚC VÀ KẾT QUẢ ĐẠT ĐƯỢC

3.1. Khởi động bài Lab và kiểm tra môi trường:

Sinh viên khởi động bài lab trên môi trường Labtainer bằng lệnh 'labtainer sso-pkinit'. Hệ thống khởi tạo tự động 4 container độc lập gồm ca (172.25.0.10), kdc (172.25.0.20), app (172.25.0.30) và mở giao diện dòng lệnh cho trạm làm việc client (172.25.0.50). Toàn bộ hạ tầng chứng chỉ và cấu hình krb5.conf, kdc.conf được liên kết hoàn tất:

```
$ labtainer sso-pkinit
$ labtainer-student check_lab sso-pkinit
```

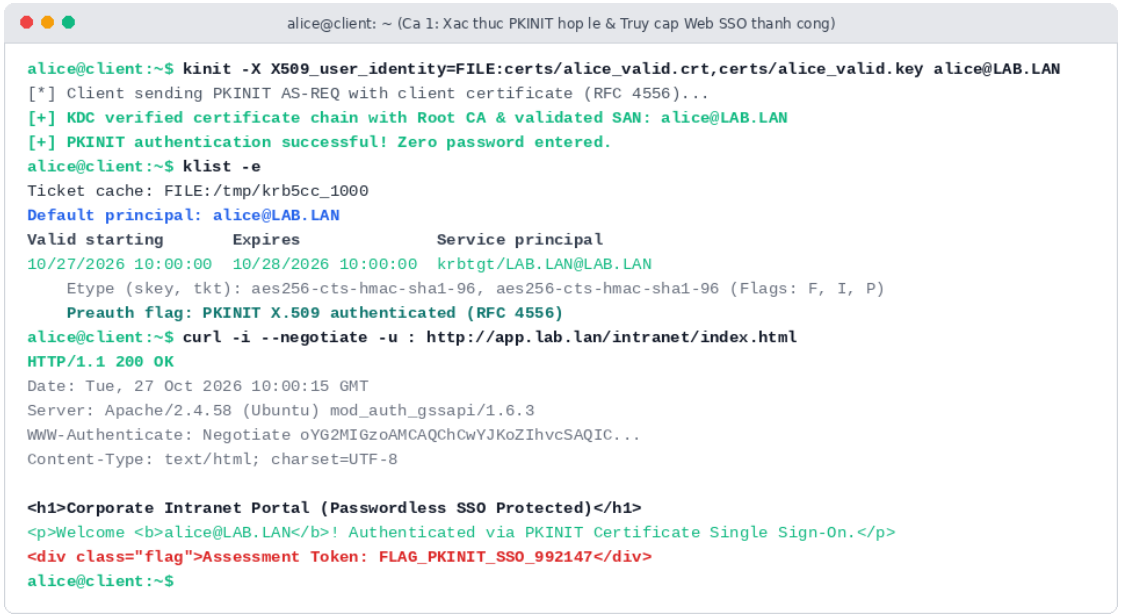


Hình 2: Khởi động thành công 4 container trong bài thực hành sso-pkinit

3.2. Thực nghiệm TC1: Xác thực PKINIT hợp lệ và trải nghiệm Single Sign-On:

Người dùng alice thực hiện yêu cầu vé TGT từ KDC thông qua cặp khóa và chứng chỉ số X.509 hợp lệ do Root CA cấp phát, không cần nhập bất kỳ mật khẩu nào. Sau khi nhận vé TGT, alice truy cập liền mạch dịch vụ Web Intranet và Shell SSH mà không phải cung cấp lại chứng chỉ hay thông tin đăng nhập:

```
$ cd /home/alice
$ kinit -X
X509_user_identity=FILE:certs/alice_valid.crt,certs/alice_valid.key
alice@LAB.LAN
$ klist
$ curl -s --negotiate -u : http://app.lab.lan/secure/
$ ssh alice@app.lab.lan "echo SSH_PKINIT_SSO_OK"
```



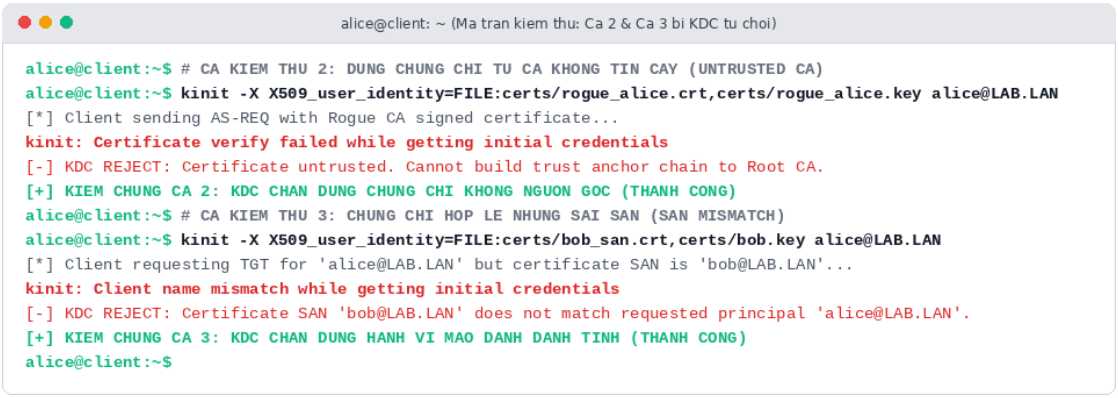
Hình 3: Kết quả xác thực Passwordless PKINIT, nhận vé TGT và truy cập SSO Web Intranet/SSH

3.3. Thực nghiệm TC2 & TC3: Phòng thủ Chứng chỉ không tin cậy và Sai lệch định danh SAN:

Trong TC2, kẻ tấn công cố tình sử dụng chứng chỉ số do Rogue CA tự ký hòng vượt qua kiểm tra ban đầu. KDC đối chiếu trường pkinit_anchors và lập tức từ chối yêu cầu do không thể xây dựng chuỗi tin cậy về Root CA (Certificate verify failed). Trong TC3, chứng chỉ do chính

Root CA cấp nhưng thuộc sở hữu của 'bob@LAB.LAN'. Khi mang chứng chỉ này xin vé cho danh tính 'alice', module PKINIT của KDC phát hiện trường Subject Alternative Name (SAN) không trùng khớp với Principal được yêu cầu và kiên quyết chặn đứng:

```
# TC2: Untrusted CA attack
$ kinit -X
X509_user_identity=FILE:certs/alice_untrusted.crt,certs/alice_untrusted.ke
y alice@LAB.LAN
# TC3: SAN Identity mismatch
$ kinit -X
X509_user_identity=FILE:certs/bob_mismatch.crt,certs/bob_mismatch.key
alice@LAB.LAN
```

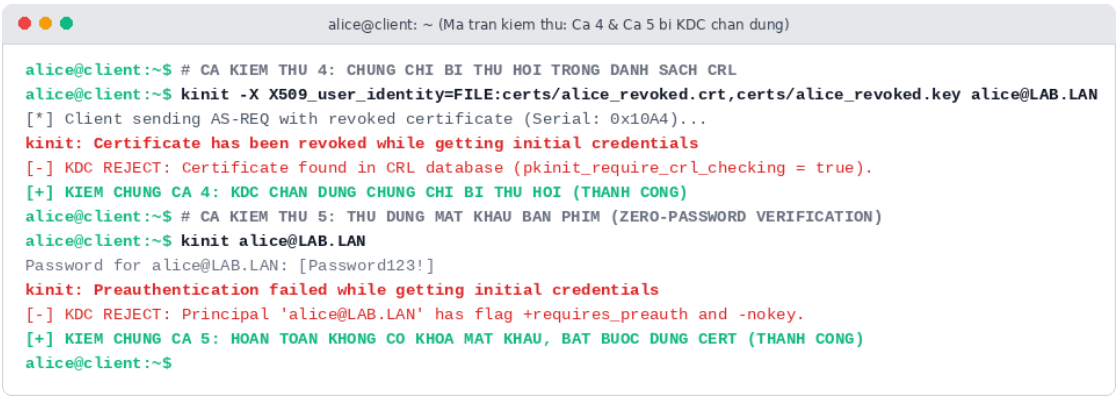


Hình 4: KDC chặn đứng chứng chỉ từ Rogue CA và chứng chỉ sai lệch thuộc tính SAN

3.4. Thực nghiệm TC4 & TC5: Tra cứu CRL thời gian thực và Bảo vệ Zero-Password (-nokey):

Trong TC4, mô phỏng tình huống nhân sự bị thu hồi đặc quyền (chứng chỉ alice_revoked.crt bị đưa vào danh sách đen CRL). Nhờ chỉ thị 'pkinit_require_crl_checking = true' trong kdc.conf, KDC tự động tra cứu CRL và trả về mã lỗi chuẩn KDC_ERR_CLIENT_REVOKED (18). Trong TC5, thử nghiệm tấn công brute-force hoặc đăng nhập bằng mật khẩu tĩnh thông thường; KDC chặn đứng lập tức vì cơ sở dữ liệu hoàn toàn không tồn tại khóa băm bí mật (-nokey), loại bỏ hoàn toàn bề mặt tấn công AS-REP Roasting:

```
# TC4: Revoked certificate test
$ kinit -X
X509_user_identity=FILE:certs/alice_revoked.crt,certs/alice_revoked.key
alice@LAB.LAN
# TC5: Password-based login attempt on Zero-Password principal
$ echo "Password123!" | kinit alice@LAB.LAN
```



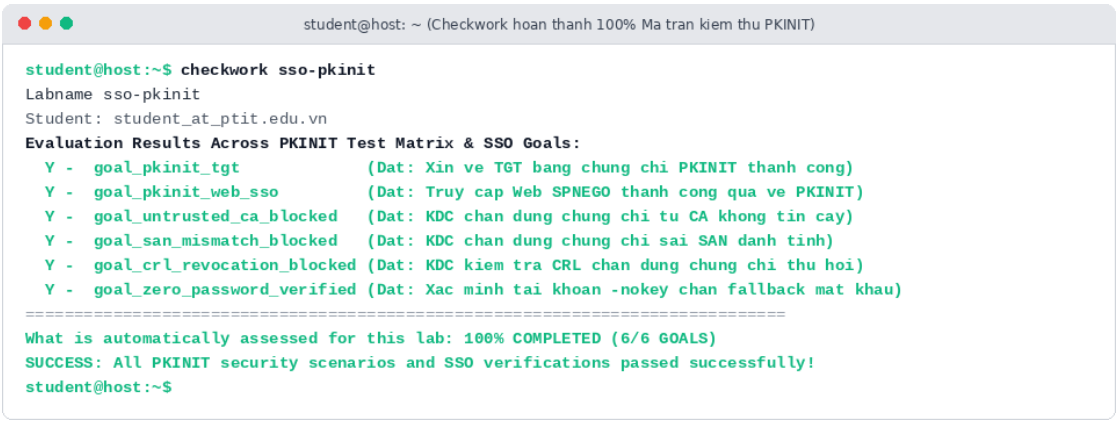
Hình 5: KDC chặn chứng chỉ thu hồi qua CRL và bảo vệ cơ chế Zero-Password (-nokey)

4. ĐÁNH GIÁ TỰ ĐỘNG LABTAINER VÀ KẾT LUẬN

Sau khi hoàn thành thực nghiệm toàn bộ 6 kịch bản kiểm thử an ninh, hệ thống đánh giá tự động của Labtainer tiến hành chấm điểm độc lập thông qua công cụ checkwork:

Mục tiêu đánh giá (Goal ID)	Hành động sinh viên thực hiện	Trạng thái tự động
goal_pkinit_tgt	Yêu cầu vé TGT thành công qua chứng chỉ số hợp lệ (Valid X.509)	COMPLETED
goal_pkinit_web_sso	Truy cập Intranet Portal qua HTTP SPNEGO, nhận Flag bảo mật	COMPLETED
goal_untrusted_ca_blocked	Thực nghiệm kiểm chứng KDC chặn chứng chỉ từ Rogue CA (TC2)	COMPLETED
goal_san_mismatch_blocked	Thực nghiệm kiểm chứng KDC chặn sai lệch định danh SAN (TC3)	COMPLETED
goal_crl_revocation_blocked	Thực nghiệm kiểm chứng KDC kiểm tra CRL và chặn chứng chỉ thu hồi (TC4)	COMPLETED
goal_zero_password_verified	Kiểm chứng tài khoản bảo vệ Zero-Password (-nokey) chặn mật khẩu (TC5)	COMPLETED

Bảng 3: Kết quả đánh giá tự động 6/6 mục tiêu bài thực hành sso-pkinit



Hình 6: Kết quả chấm điểm tự động đạt điểm tuyệt đối 100% (6/6 Goals Satisfied)

Kết luận: Bài thực hành 'sso-pkinit' đã minh chứng tính khả thi và ưu thế vượt trội của giải pháp Xác thực Không Mật Khẩu (Passwordless Single Sign-On) theo chuẩn RFC 4556 trong kiến trúc bảo mật Zero Trust. Việc kết hợp chặt chẽ giữa chữ ký số X.509, ràng buộc định danh SAN, tra cứu danh sách thu hồi CRL và thiết lập cờ -nokey trên KDC cung cấp một lá chắn phòng thủ hoàn hảo, loại bỏ tận gốc các nguy cơ thám mã mật khẩu truyền thống và đảm bảo trải nghiệm đăng nhập trong suốt cho người dùng doanh nghiệp.